

คู่มือประกอบการพัฒนาระบบ

Administrative Manual

การพัฒนา API สำหรับผู้ให้บริการ (Relying Party : RP)

รุ่นเอกสาร 1.0.1

25 กันยายน 2566

สำนักบริหารการทะเบียน กรมการปกครอง

เอกสารควบคุมของสำนักบริหารการทะเบียน กรมการปกครอง
ห้ามทำสำเนาหรือพิมพ์เผยแพร่ส่วนหนึ่งส่วนใดหรือทั้งหมดของเอกสารนี้ก่อนได้รับอนุญาต

ประวัติการแก้ไขเอกสาร

วันที่	รุ่นเอกสาร	รายละเอียดการปรับแก้	หมายเหตุ
17 กันยายน 2563	0.0.01	- จัดทำเอกสารต้นแบบ	
17 กันยายน 2563	0.0.02	- แก้ไข url ของการ Request ทุกข้อ	
28 ตุลาคม 2563	0.0.03	- แก้ไขเรื่อง สถาปัตยกรรมการให้บริการข้อมูลผ่าน BORA API, State [Option] นำออก	
18 ธันวาคม 2563	0.0.04	- แก้ไขชื่อ พารามิเตอร์ oauth2 - เพิ่ม API Introspect - นำ Refresh Token ออก	
9 กุมภาพันธ์ 2564	0.0.05	- เพิ่ม OpenID Connect - แก้ไข API Introspect	
1 มิถุนายน 2564	0.0.06	- แก้ไข API Revoke - ยกเลิก API Consent	
9 กันยายน 2564	0.0.07	- แก้ไข Authentication Request URL	
13 มกราคม 2566	0.8.0	- เปลี่ยน Endpoint ของ service oauth2 - เปลี่ยนชื่อ scope ให้ตรงตามมาตรฐาน - เปลี่ยนรูปแบบข้อมูลของ scope บางตัว ให้ตรงตามมาตรฐาน ได้แก่ address, birthdate, gender - เพิ่ม API สำหรับการทำ Consent	
13 มีนาคม 2566	0.9.0	- เปลี่ยนชื่อเป็นแอปพลิเคชัน ThalD	
13 กรกฎาคม 2566	1.0.0	- เพิ่ม scope	
25 กันยายน 2566	1.0.1	- เปลี่ยนชื่อเว็บไซต์จาก idp เป็น digitalid	

สารบัญ

หัวข้อ

1. บทนำ
2. สถาปัตยกรรมระบบ
3. ข้อกำหนดในการเรียกใช้บริการข้อมูล
4. ขั้นตอนการขอใช้บริการข้อมูล
5. รายละเอียดติดต่อ / สอบถาม
6. พารามิเตอร์ในกระบวนการแลกเปลี่ยนข้อมูลการยืนยันตัวตน
 - 6.1. Authentication
 - 6.2. การขอ Token
 - 6.3. การขอ Token Introspect
 - 6.4. การขอ Token Revocation
7. ข้อเสนอแนะ

1. บทนำ

1.1 หลักการและเหตุผล

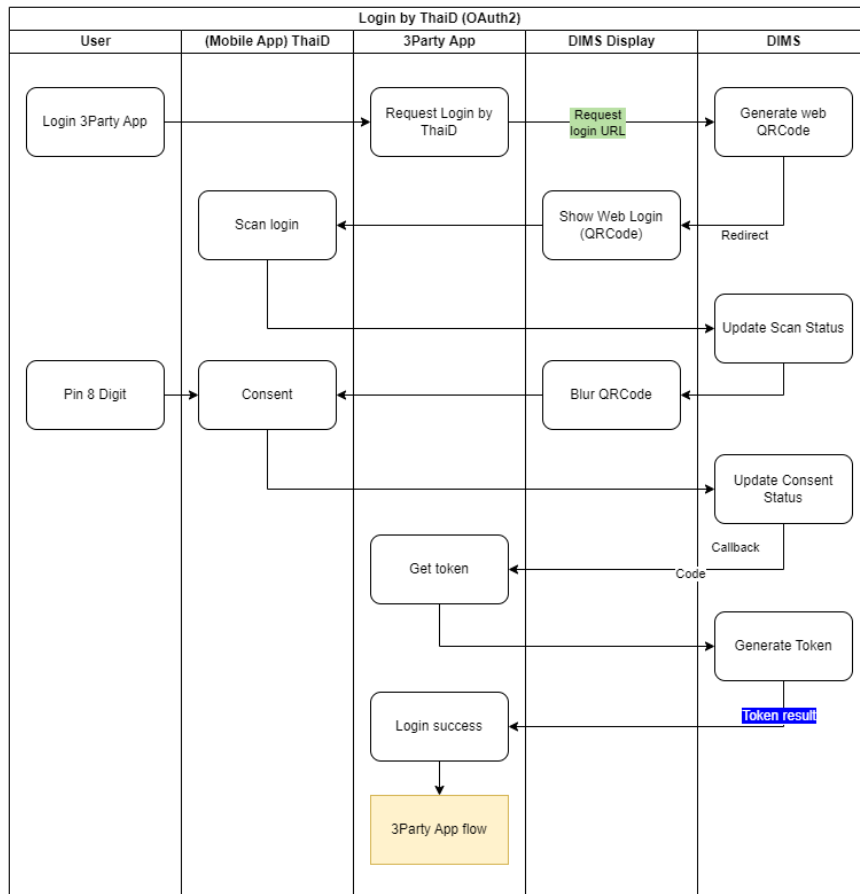
เพื่อพัฒนาระบบการปฏิบัติงาน IdP ในการพิสูจน์และยืนยันตัวตนทางดิจิทัล และการให้บริการประชาชนที่มีความน่าเชื่อถือตามมาตรฐานสากล

1.2 วัตถุประสงค์

เพื่อให้หน่วยงานผู้ให้บริการเข้าใจการทำงานของระบบ IdP ของกรมการปกครอง และสามารถพัฒนาหรือเริ่มต้นศึกษาแนวทางปฏิบัติเบื้องต้นได้

2. สถาปัตยกรรมระบบ

2.1 สถาปัตยกรรมการให้บริการข้อมูลผ่าน BORA API



Query String
+ scope + response_type + client_id + redirect_uri + state *optional

Request login URL

`https://imauth.bora.dopa.go.th/api/v2/oauth2/ε`
`{{client_id}}&redirect_uri={{redirect_uri}}`

Ex.

`https://imauth.bora.dopa.go.th/api/v1/oauth2/ε`
`dob&response_type=code&state=someRandc`

Token result
+ token + refresh token

3. ข้อกำหนดในการเรียกใช้บริการข้อมูล

ข้อกำหนดของการเรียกใช้ข้อมูลผ่าน BORA API โดยหน่วยงานสามารถพิจารณาได้จาก

	หัวข้อ	ข้อกำหนด
1	การลงทะเบียนขอใช้งาน	หน่วยงานต้องมีหนังสือขออนุญาตการใช้งานแอปพลิเคชัน ThaiID และมอบหมายผู้ประสานงานระหว่างหน่วยงานกับกรมการปกครองในการพัฒนา รวมไปถึงการเพิ่มเจ้าหน้าที่/ผู้พัฒนาแอปพลิเคชันของหน่วยงาน ซึ่งต้องได้รับการอนุญาตจากอธิบดีกรมการปกครองแล้วเท่านั้น
2	ผู้ขอใช้งาน	กรมการปกครองขอสงวนสิทธิในการอนุมัติ/อนุญาต การขอใช้งานสำหรับผู้ใช้งานของหน่วยงานภายนอก โดยจะทำการพิจารณาจากเอกสารของหน่วยงาน และการยืนยันจากผู้ประสานงานของหน่วยงานนั้น ๆ

4. ขั้นตอนการขอใช้บริการข้อมูล

หน่วยงานที่ต้องการใช้บริการแอปพลิเคชัน ThaiID สามารถดำเนินการขอใช้บริการได้ดังนี้

1) เข้าสู่เว็บไซต์ <https://digitalid.bora.dopa.go.th> เพื่อขอลงทะเบียนหน่วยงาน และสามารถเพิ่มเจ้าหน้าที่ผู้รับผิดชอบในการพัฒนาแอปพลิเคชันของหน่วยงานได้ไม่เกิน 10 คน ในการขอใช้งานระบบ (เริ่มต้นให้บริการ 1 กุมภาพันธ์ 2564)

2) พิมพ์แบบฟอร์มจากระบบ และจัดทำหนังสือราชการส่งถึงกรมการปกครอง (หนังสือที่ส่งถึงกรมการปกครอง ต้องระบุข้อมูลผู้ประสานงานให้ชัดเจน เช่น เลขประจำตัวประชาชน, ชื่อ-นามสกุล, ตำแหน่ง, หมายเลขโทรศัพท์ที่ติดต่อได้, อีเมล เป็นต้น เพื่อให้กรมการปกครองสามารถติดต่อสอบถามข้อมูล/ประสานงานได้โดยง่าย) หนังสือราชการจะต้องลงนามโดยผู้มีอำนาจลงนามของหน่วยงาน โดยกรมการปกครองจะใช้ในการพิจารณาอนุญาต/ไม่อนุญาต ให้หน่วยงานสามารถพัฒนาแอปพลิเคชัน และเชื่อมโยงกับกรมการปกครองในการพิสูจน์และยืนยันตัวตนผ่านแอปพลิเคชัน ThaiID ได้หรือไม่

3) เมื่อเจ้าหน้าที่ของกรมการปกครองพิจารณา อนุญาตหรือไม่อนุญาต จะส่งข้อความแจ้งเตือนผ่านแอปพลิเคชัน (ThaiID) เพื่อแจ้งให้ทราบ

4) เมื่อได้รับอนุญาตให้ใช้งาน หน่วยงานสามารถขอเพิ่มระบบงานบริการได้ด้วยตนเอง และจะได้รับข้อมูลเพื่อนำไปใช้ในการพัฒนาระบบให้บริการของตนเอง

5. รายละเอียดติดต่อ / สอบถาม

สำนักบริหารการทะเบียน กรมการปกครอง กระทรวงมหาดไทย

โทร 0-2791-7522, 0-2791-7523-5 email d.dopaid@gmail.com

6. พารามิเตอร์ในกระบวนการแลกเปลี่ยนข้อมูลการยืนยันตัวตน

กระบวนการแลกเปลี่ยนข้อมูลการยืนยันตัวตนกับระบบของกรมการปกครอง มีการส่งผ่านข้อมูลที่ต้องการพารามิเตอร์ ดังต่อไปนี้

6.1 Authentication

6.1.1 Authentication Request

Web Application/Mobile Application ของ RP จะส่ง authentication request ด้วย HTTPS GET request ไปยัง <https://imauth.bora.dopa.go.th/api/v2/oauth2/auth/>

ค่าพารามิเตอร์ของ Authentication Request

พารามิเตอร์	รายละเอียด
response_type	ระบุค่าเป็น “code” เนื่องจากเป็นการร้องขอสิทธิการเข้าถึงข้อมูล แบบ authorization code
client_id	ระบุค่า client identifier ที่กรมการปกครองออกให้กับ RP ที่ผ่านการลงทะเบียนแล้ว
redirect_uri	ระบุค่า URI ที่ RP ลงทะเบียนไว้กับกรมการปกครอง เพื่อใช้ในการรับ authorization code
scope	ขอบเขตหรือชุดของข้อมูลที่ RP ร้องขอสิทธิการเข้าถึง โดยเลือกระบุค่าจากข้อมูลที่กรมการปกครองเปิดให้ร้องขอ ดังนี้ (1) pid คือ หมายเลขประจำตัวประชาชน 13 หลัก (2) name คือ ชื่อ-นามสกุล ภาษาไทย (3) name_en คือ ชื่อ-นามสกุล ภาษาอังกฤษ (4) birthdate คือ วัน เดือน ปีค.ศ.เกิด (เช่น 1989-12-28) (5) address คือ ที่อยู่ตามหน้าบัตรประจำตัวประชาชน (6) given_name คือ ชื่อ ภาษาไทย (7) middle_name คือ ชื่อกลาง ภาษาไทย (8) family_name คือ นามสกุล ภาษาไทย

พารามิเตอร์	รายละเอียด
	(9) given_name_en คือ ชื่อ ภาษาอังกฤษ (10) middle_name_en คือ ชื่อกลาง ภาษาอังกฤษ (11) family_name_en คือ นามสกุล ภาษาอังกฤษ (12) gender คือ เพศ (เช่น male) (13) smartcard_code คือ เลขไต่รูป (14) title คือ คำนำหน้านามภาษาไทย (15) title_en คือ คำนำหน้านามภาษาอังกฤษ (16) ial คือ ระดับความเข้มข้นในการพิสูจน์ตัวตน (17) date_of_issuance คือ วันที่ออกบัตร (18) date_of_expiry คือ วันที่บัตรหมดอายุ (19) openid คือ id_token ที่มีข้อมูลผู้ใช้บริการที่ RP ร้องขอ หากมีข้อมูลหลายอัน ให้แยกข้อมูลแต่ละอันด้วยการเว้นวรรค 1 วรรค (หรือ %20 ในระบบ Base64 url encoded)
state	random string ใช้ในการตรวจสอบความสัมพันธ์ระหว่าง request จาก RP กับ response จาก server ของกรมการปกครอง

ตัวอย่างการใช้งานเป็นดังนี้

Method	GET
URL	https://imauth.bora.dopa.go.th/api/v2/oauth2/auth/?response_type=code &client_id={{clientIdFromDOPA}}&redirect_uri=https://rp.example.org/api/callback &scope=pid%20name%20birthdate%20openid&state=af0ifjsldkj
Header	“Content-type”: “application/x-www-form-urlencoded”

6.1.2 Authentication Response

Authorization code เป็น credential ที่ออกโดย server ของกรมการปกครองให้กับ Web Application/Mobile Application ของ RP เพื่อใช้เป็นหลักฐานว่าผู้ใช้บริการได้ผ่านการยืนยันตัวตนและให้ความยินยอมในการเปิดเผยข้อมูลแล้ว server ของกรมการปกครองจะส่ง authorization code ให้กับ Web

Application/Mobile Application ของ RP ด้วยการส่ง HTTPS response กลับไปยัง redirect URI ตามที่ลงทะเบียน

ค่าพารามิเตอร์ของ Authentication Response

พารามิเตอร์	รายละเอียด
code	authorization code เพื่อใช้ในการร้องขอ access token
state	state เป็นค่าเดียวกันกับ state ใน authentication request

ตัวอย่างการใช้งานเป็นดังนี้

Response Status	302 Found
Payload	https://rp.example.org/api/callback?code=nnqtYcoik7cjtHQYyn3Af8uk4LG3rYYh &state=af0ifjsldkj

6.1.3 Authentication Error Response

หากมีข้อผิดพลาดในกระบวนการยืนยันตัวตนนอกเหนือจากปัญหาจาก redirect URI เช่น ผู้ใช้งานไม่ผ่านการยืนยันตัวตน หรือไม่ยินยอมที่จะเปิดเผยข้อมูล server ของกรมการปกครองจะแจ้ง error code ให้กับ Web Application /Mobile Application ของ RP ด้วยการส่ง HTTPS response กลับไปยัง redirect URI ตามที่ลงทะเบียนไว้

ค่าพารามิเตอร์ของ Authentication Error Response

พารามิเตอร์	รายละเอียด
error	error code แจ้งสาเหตุของข้อผิดพลาดที่เกิดขึ้น
error_description	คำอธิบาย error code ในรูปแบบ text
error_uri	URI ที่ระบุข้อมูลเพิ่มเติมของ error อาจเป็น Webpage
state	state เป็นค่าเดียวกันกับ state ใน authentication request

ตัวอย่าง error code ของ authentication error response อ้างอิงหัวข้อที่ 7

ตัวอย่างการใช้งานเป็นดังนี้

Response Status	302 Found
-----------------	-----------

Payload	https://rp.example.org/api/callback?error=invalid_request &error_description=Unsupported%20response_type&state=af0ifjsldkj
---------	---

6.2 การขอ Token

6.2.1 Token Request

Web Application/Mobile Application ของ RP ใช้ authorization code เพื่อร้องขอข้อมูลในการยืนยันตัวตน ผู้ใช้บริการจากกรมการปกครอง ด้วยการส่ง HTTPS POST request

ค่าพารามิเตอร์ของ Access Token Request

พารามิเตอร์	รายละเอียด
authorization	ใช้ค่า “Basic” + Base64({{client_id}}:{{client_secret}})
grant_type	ใช้ค่า “authorization_code”
code	authorization code ที่ได้รับมาก่อนหน้า
redirect_uri	URI เป็นค่าเดียวกันกับ redirect_uri ใน authentication request

ตัวอย่างการใช้งานเป็นดังนี้

Method	POST
URL	https://imauth.bora.dopa.go.th/api/v2/oauth2/token/
Header	{ “Content-type”: “application/x-www-form-urlencoded”, “Authorization”: “Basic authorization” }
Body	grant_type=authorization_code code=code redirect_uri=redirect_uri

6.2.2 Token Response

Server ของกรมการปกครองตรวจสอบ authorization code ที่ได้รับ หากถูกต้อง ก็จะส่ง token response พร้อมกับข้อมูลยืนยันตัวตนกลับมายัง web/mobile application ของ RP ด้วยการส่ง HTTPS POST response กลับไปยัง redirect URI ตามที่ระบุใน token request โดย token response

ค่าพารามิเตอร์ของ Token Response

พารามิเตอร์	รายละเอียด
access_token	String มีอายุ 15 นาที
token_type	ใช้ค่า “Bearer”
expire_in	วัน เวลาที่ access token หมดอายุ รูปแบบ Unix timestamp (second)
scope	scope ของข้อมูลที่ได้รับ
*id_token	Option ถ้า scope=openid คือ id_token ที่มีข้อมูลผู้ใช้บริการที่ RP ร้องขอ
**scope value	String ที่เก็บ value ของ scope นั้น ๆ

* id_Token จะเก็บข้อมูลตามมาตรฐาน OpenID Connect โดยสามารถตรวจสอบกระบวนการ verify ได้ที่ <https://imauth.bora.dopa.go.th/.well-known/openid-configuration> จะ return เฉพาะกรณีกำหนด scope openid เท่านั้น

** scope value เช่น “pid”: “หมายเลขประจำตัวประชาชน 13 หลัก” “name”: “ชื่อ-นามสกุล ภาษาไทย” เป็นต้น จะ return ให้เฉพาะกรณีไม่กำหนด scope openid

ตัวอย่างการใช้งานเป็นดังนี้

กรณีไม่กำหนด scope openid

Response Status	200 OK
Payload	{ "expire_in": 1612857374, "access_token": "access_token", "refresh_token": "refresh_token", "token_type": "Bearer", "scope": "pid name", "pid": " pid ", "name": " name " }

กรณีกำหนด scope openid

Response Status	200 OK
Payload	{ "expire_in": 1612857374, "access_token": "access_token", "refresh_token": "refresh_token", "token_type": "Bearer", "scope": "pid name openid", "id_token": "id_token jwt", }

ตัวอย่าง error code response อ้างอิงหัวข้อที่ 7

6.2.3 ID Token

id_token จะมีข้อมูลผู้ให้บริการที่ RP ร้องขอ มีอายุใช้งานตามที่กำหนด มีการลง signature จากกรรมการปกครอง และมีการเข้ารหัสด้วย Base64 ภายใน id_token จะมีค่าพารามิเตอร์ดังนี้

พารามิเตอร์	รายละเอียด
at_hash	Access Token hash value
aud	App ที่สามารถใช้งานได้
exp	วัน เวลา หมดอายุ
iat	วัน เวลา ที่ออก token
iss	ผู้ที่ออก token
sub	Subject Identifier
*scope value	String ที่เก็บ value ของ scope นั้น ๆ

* scope value เช่น “pid” : “หมายเลขประจำตัวประชาชน 13 หลัก” “name” : “ชื่อ-นามสกุล ภาษาไทย” เป็นต้น

ตัวอย่างข้อมูลผู้ให้บริการที่ RP ร้องขอ

pid	<i>pid</i>
name	<i>name</i>
birthdate	<i>birthdate</i>

6.3 การ Token Introspect

6.3.1 Token Introspect Request

ค่าพารามิเตอร์ Token Introspect Request

พารามิเตอร์	รายละเอียด
token	token มีอายุ 15 นาที

ตัวอย่างการใช้งานเป็นดังนี้

Method	POST
URL	https://imauth.bora.dopa.go.th/api/v2/oauth2/introspect/
Header	{ "Content-type": "application/x-www-form-urlencoded", "Authorization": "Basic authorization" }
Body	token=Bearer token

6.3.2 Token Introspect Response

ตัวอย่างการใช้งานเป็นดังนี้

Response Status	200 OK
Payload	{ "active": true, "sub": "1639800072121", "scope": "pid name" }

6.3.3 Token Introspect Error Response

ตัวอย่างการใช้งานเป็นดังนี้

Response Status	400 Bad Request
Payload	{ "error": "invalid_request", "error_description": "The body is invalid" }

6.4 การ Token Revocation

6.4.1 Token Revocation Request จะมีค่าพารามิเตอร์ ดังนี้

พารามิเตอร์	รายละเอียด
token	token ที่ต้องการยกเลิก

ตัวอย่างการใช้งานเป็นดังนี้

Method	POST
URL	https://imauth.bora.dopa.go.th/api/v2/oauth2/revoke/
Header	{ “Content-type”: “application/x-www-form-urlencoded”, “Authorization”: “Basic authorization” }
Body	token = Bearer token

6.4.2 Token Revocation Response

ตัวอย่างการใช้งานเป็นดังนี้

Response Status	200 OK
Payload	{ “status”: “OK”, “message”: “revoked” }

7. ข้อยกเว้น

- Status คือ HTTP Status Code ที่ระบบจะแจ้งกลับ (Response) มายังต้นทางทราบ ดังนี้

Code Response	Error	Error Description
400	invalid_request	The require parameter is missing or invalid
400	invalid_scope	The scope is invalid
400	invalid_request	The redirect or callback url mismatch or invalid
400	invalid_request	Invalid Authorization Code
400	unsupported_response_type	Unsupported response type
400	unsupported_grant_type	Unsupported grant type
400	unsupported_token_hint	Unsupported token hint
400	unsupported_token_type	Unsupported token type
400	duplicate_request	The duplicate request is not allowed
400	server_error	Something went wrong, please try again in the moment
401	unauthorized_client	The client is not authorized
401	invalid_client	Client id not found
401	user_denied	User denied the request (disapproved)
401	invalid_refresh_token	Verify refresh token failed
401	invalid_refresh_token	Invalid refresh token
401	invalid_refresh_token	Cannot refresh access token
401	access_denied	You're not allowed
401	access_denied	You're not allowed as Authorative Source
401	access_denied	You don't have permission to access this service
404	not found data	

-
- Response จะอยู่ในรูปแบบ JSON แต่มีบางคำสั่งจะไม่มีข้อมูลตอบกลับ ขึ้นอยู่กับ Status
 - ทุก request parameters จะต้องมีการกำหนดค่า ยกเว้นที่ระบุไว้เป็น [optional]

CONFIDENTIAL